

Once another service is given by NetBIOS, on port 137. It's the Windows implementation of DNS.

Net view is a standard command inside Windows. With it, the net bios server will reply, giving information about machines accessible in a domain. It's a quick way to enumerate windows domains.

Normally, NBNS is efficient when inside a local network, however there're ways to use this service over TCP. If the port is open over the perimeter firewall, then enumeration can be done outside as well.

NetviewX is another tool which can be used to identify specific services.

What are the countermeasures on this enumeration? Basically, they're the one we've seen so far, like blocking the port at the firewall, restrict the use of the port to some specific clients, disable Alerter and Messenger services running on Windows machines.

Blocking completely the service might stop some Microsoft applications from working.

We also have null sessions attack, which are basically anonymous connections (like anonymous FTP). We talk about the NetBIOS session protocol, running on port 139.

Some Microsoft services use this protocol, so it cannot be turned off completely. The user might run the `net view` command, and get access denied as a response. If the same user, however, using an empty string for username and empty string for password (thus initiating a null session), runs the command, he will get access to wanted resources. This service is still used in some Windows networks. Once access is granted, what information can it be retrieved? We can have the user shares, user accounts and password policies, so the passwords set by the administrator.

One tool to do this is given by `dumpsec`, allowing us to enumerate all information about file permissions, services, etc.

Another type of enumeration which can be done is given by Registry enumeration. In order to enumerate them, we need the `reg` utility, a Microsoft built-in utility, used to read and modify registries. Requires administration privileges on Windows servers.

We also have the user accounts enumeration.

How are accounts implemented in Windows? We have specific Security Identifiers

(SID), which is an internal kernel representation of the user account. It's a string of number, uniquely identifying the user. Conceptually, it's an access control mechanism at kernel level.

How are they implemented? The initial part of the number, `S-1` is the same for everyone, while the rest consists of random numbers. The last number identifies the user specifically, if it is equivalent to 500 then this is the SSID of the administrator, while if it goes above 1000 it's a standard user.

To enumerate users, we can use the `user2sid` and `sid2user` commands. They even work remotely, even if blocking anonymous connections. It can be used to find the administrator account name, even if it's renamed.

The countermeasures are given by the usual ones, like blocking the ports 139 and 445, set `RestrictAnonymous` registry to 1 (or 2, in later versions of Windows), helping to block null sessions. This specific action do not apply, however, to remote registry access, so we must ensure that it's locked down.

Another protocol is given by SNMP, running on port 161. It's used both by Windows and Linux. One way to call this protocol is Security Not My Problem. It was designed for network management, and monitoring it provides inside information on network devices, software and systems. Administrators use this protocol to remotely manage routers and other network devices.

It has a minimal security measure, given by community strings. They act like passwords. We can classify those strings as read-only, read-write and trap.